

CONFIDENTIAL · INTERNAL AUDIT REPORT

CNA Platform

Sprint 5 Audit

Professional-grade assessment against WCAG 2.1 AA, W3C HTML5/CSS Standards, and OWASP Top 10 (2021) / ASVS v4.0

PLATFORM

MVP-Cloud Network
Assessment

AUDIT DATE

2026-05-28

BRANCH

main @ HEAD

PRIMARY SURFACE

apps/cna-web (Next.js
15)

AUDIT METHOD

Full Source Code
Review

STANDARDS

WCAG 2.1 · W3C ·
OWASP

47

TOTAL
FINDINGS

5

CRITICAL

18

HIGH

21

MEDIUM

8

LOW



Executive Summary

A full source-code audit of the **CNA Platform** (`apps/cna-web` — Next.js 15, React 19, TypeScript, Tailwind CSS v4, Auth.js v5, Prisma) was conducted against three industry standards: **WCAG 2.1 Level AA**, **W3C HTML5/CSS specifications**, and the **OWASP Top 10 (2021) / ASVS v4.0**. All 47 findings were identified through direct code analysis — not automated scanning — providing higher fidelity than tool-only approaches.

The platform is well-architected with solid security foundations: Entra ID authentication, server-side session validation on every protected route, parameterised Prisma queries eliminating SQL injection risk, and a layered CSP configuration. However, several gaps require remediation before enterprise client deployment or any accessibility certification claim.

✓ Strengths

- Entra ID / OIDC authentication with DB-backed sessions
- Server components validate membership on every protected route
- Parameterised Prisma ORM — no SQL injection risk
- CSP header present with `frame-ancestors 'none'`
- X-Frame-Options, X-Content-Type-Options, HSTS deployed
- Server Actions use Auth.js CSRF protection for form submissions
- External links use `rel="noopener noreferrer"`
- Select elements have `aria-label` attributes
- `lang="en"` set on root HTML element

🚨 Critical Gaps

- `unsafe-inline` in script-src negates XSS protection
- Help modal has no focus trap, no Escape key, no dialog role
- Navigation SVG icons are invisible to screen readers
- Collapsible findings rows missing `aria-expanded`
- No rate limiting on expensive Server Actions
- SSRF risk on unvalidated `customerLogoUrl` input
- Colour contrast fails WCAG AA on secondary text
- No global `focus-visible` styles for keyboard nav

🚨 RECOMMENDED ACTION

The 5 CRITICAL and top 10 HIGH findings should be resolved before presenting the platform to enterprise clients or making any WCAG AA conformance claims. Wave 1 items (7 tasks) can be

completed in approximately 2–3 developer days.

Sprint 5 Recommended Execution Order

1. **[OWA-01]** Implement nonce-based CSP — replace `unsafe-inline` in `script-src` (`next.config.ts` L23)
2. **[WAI-03]** Rewrite `sp-help-modal.tsx` using native `<dialog>` or Radix UI Dialog primitive
3. **[WAI-01/02]** Add `aria-hidden` / `aria-label` to all sidebar SVG icons and toggle button
4. **[WAI-04/05]** Add `aria-expanded` + `aria-controls` to findings collapsible rows
5. **[OWA-07]** Add domain allowlist validation for `customerLogoUrl` (SSRF fix)
6. **[WAI-10]** Add global `:focus-visible` styles to `globals.css`
7. **[WAI-09]** Fix colour contrast — adjust `text-navy-400` token or dark-mode alias
8. **[WAI-16]** Add skip-to-main-content link in dashboard layout
9. **[OWA-02]** Add per-user rate limiting to AI generation and discovery Server Actions
10. **[W3C-02]** Add `aria-hidden="true"` `focusable="false"` to all decorative SVGs



OWASP Top 10 & ASVS v4.0 Findings

17 findings

WAVE 1 — CRITICAL

Must fix before first paid client

CRITICAL

OWA-01

unsafe-inline Script CSP in Production

OWASP A05:2021 Security Misconfiguration

ASVS 14.4.6

next.config.ts L23

The production Content Security Policy contains `"script-src 'self' 'unsafe-inline'"`, completely disabling XSS protection. Any stored or reflected XSS payload executes in full. The code comment acknowledges this is known ("nonce-based script CSP is the recommended next upgrade") — but it remains unimplemented. Next.js 15 has first-class nonce support via middleware.

REMEDIATION

Generate a nonce in Next.js middleware, pass via `x-nonce` header, and update the CSP to `"script-src 'self' 'nonce-{NONCE}'"`. This also requires wrapping all inline scripts with the nonce prop.

CRITICAL

OWA-07

customerLogoUrl Not Validated — Server-Side Request Forgery (SSRF) Risk

OWASP A10:2021 SSRF

ASVS 5.2.6

deliverables/actions.ts L93

The `customerLogoUrl` field is read verbatim from form input and passed to the AI content generator without any URL validation. If the generated HTML causes a server-side fetch (or embeds the URL in a way that triggers fetching), internal Azure metadata endpoints (e.g., `http://169.254.169.254/`) could be probed. Even without server fetching, an unsanitised URL in AI-generated HTML poses XSS risk.

REMEDIATION

Validate `customerLogoUrl` against an explicit domain allowlist before use. Reject any URL whose `hostname` is not in the approved CDN list (`cdn.cbts.com`, `storage.azure.com`, etc.).

**WAVE 2 —
HIGH****Required for OWASP rating and production hardening****HIGH**

OWA-02

No Rate Limiting on Expensive Server Actions

OWASP A07:2021 Auth Failures

ASVS 2.2.1

deliverables/actions.ts · discovery/actions.ts

Server Actions for AI generation (`generateDeliverable`, `generateAllAssessments`) and discovery (`startDiscovery`, `startAllDiscovery`) have no rate limiting. An authenticated user or session replay can trigger hundreds of expensive Azure OpenAI and Azure discovery operations in rapid succession, causing cost overruns and DoS.

REMEDIATION

Implement per-user rate limiting using `@upstash/ratelimit` or a sliding-window Redis counter. Limit: 5 AI generation requests per 60 seconds per user. 1 discovery job per credential per 5 minutes.

HIGH

OWA-03

CSRF Protection Bypassed on Delete Engagement Action

OWASP A01:2021 Broken Access Control

ASVS 4.2.2

`delete-engagement-button.tsx` L28-30

The delete button invokes the Server Action via `startTransition()` with a manually constructed `FormData` object — bypassing the Auth.js v5 CSRF cookie check that is tied to `<form>` element submissions. This allows the action to be triggered from cross-origin pages if the session cookie is present.

REMEDIATION

Wrap the delete action in a proper `<form>` element with a submit button, or use Auth.js `getCsrfToken()` to generate and manually verify CSRF tokens for programmatic calls.

HIGH

OWA-04

Middleware Cookie Fallback Accepts Non-Secure Tokens in All Environments

OWASP A07:2021

ASVS 3.3.1

`middleware.ts` L19-21

The middleware accepts both `__Secure-authjs.session-token` and the non-Secure `authjs.session-token` cookie in all environments, including production. An invalid or forged non-Secure cookie passes the middleware guard, loading the dashboard layout and leaking engagement names and user email before the server component validates the real session.

REMEDIATION

Guard the non-Secure fallback with `process.env.NODE_ENV !== 'production'` to ensure production only accepts the `__Secure-` prefixed cookie.

HIGH

OWA-05

Job ID Enumeration via Timing Side Channel

OWASP A01:2021 Broken Access Control

ASVS 4.1.2

`api/discovery-jobs/[jobId]/route.ts` L9-27

The API route returns `401` for unauthenticated requests (fast, no DB hit) and `404` for valid-but-inaccessible job IDs (slower, DB hit). An unauthenticated attacker can probe CUID-space job IDs and use the timing difference to confirm whether a given job ID exists in the database.

REMEDIATION

Ensure the 401 response is returned before any database operations. The current code flow is correct — audit that no future refactor moves the DB lookup above the auth check.

HIGH

OWA-06

No Server-Side MIME / Magic-Byte Validation on Document Uploads

OWASP A04:2021 Insecure Design

ASVS 12.1.1

`documents/` `upload action`

With a 52 MB body size limit configured for document uploads, there is no visible server-side content-type enforcement or magic-byte validation. Users can upload files with spoofed MIME types (e.g., an executable disguised as a PDF) which will be stored in Azure Blob and potentially served back to the browser.

REMEDIATION

In the document upload Server Action, validate file magic bytes using the `file-type` npm package. Allowlist: `application/pdf` , `text/plain` , `image/png` , `image/jpeg` . Reject all others.

WAVE 3 — MEDIUM / LOW

Defence-in-depth and best practices

ID	Severity	Finding	Standard	File
OWA-08	Medium	Audit lib/auth.ts — enforce useSecureCookies in production	ASVS 3.4.1	lib/auth.ts
OWA-09	Medium	Replace window.confirm() with accessible modal confirmation	OWASP A04 / WCAG 3.3.4	delete-engagement-button.tsx
OWA-10	Medium	Add Zod schema validation to progressLog JSON parse	OWASP A08 / ASVS 5.1.2	connections-panel.tsx L90-96

ID	Severity	Finding	Standard	File
OWA-11	Medium	X-Frame-Options SAMEORIGIN on presentation routes — document intent explicitly	OWASP A05 / ASVS 14.4.7	next.config.ts L61–63
OWA-12	Medium	Map raw Azure SDK errors to user-friendly messages — do not expose internals	OWASP A05 / ASVS 7.4.1	deliverables/actions.ts L156
OWA-13	Medium	Expand Permissions-Policy header (payment, usb, serial, hid, bluetooth, display-capture)	OWASP A05	next.config.ts L14
OWA-14	Medium	Add preload directive to Strict-Transport-Security header	OWASP A05	next.config.ts L10
OWA-15	Medium	img-src data: allows arbitrary data URIs — restrict to specific use case	OWASP A05 / CSP Level 3	next.config.ts L27
OWA-16	Low	font-src 'self' correct but build-time font download is fragile — document assumption	W3C CSP Level 3	next.config.ts L29
OWA-17	Low	No Expect-CT header — flagged by enterprise security scanners	OWASP A05	next.config.ts



WCAG 2.1 Level A & AA Findings

23 findings

AUDIT METHOD

All findings were identified through direct JSX/TSX source code analysis. Browser-based automated scanning (axe, WAVE) was not used — findings reflect real structural and semantic issues rather than surface-level heuristics.

WAVE 1 — CRITICAL (LEVEL A FAILURES)

Blocking basic assistive technology use

CRITICAL

WAI-01

All Navigation SVG Icons Have No Accessible Name (SC 1.1.1)

WCAG 1.1.1 Non-text Content — Level A

engagement-sidebar.tsx L12-88

Every `NAV_ITEMS` entry contains an inline SVG with no `<title>`, `aria-label`, or `aria-hidden`. When the sidebar is collapsed, the SVG icons are the only content in each navigation link. Screen readers announce raw path data or nothing meaningful.

REMEDIATION

For decorative icons next to visible text: add `aria-hidden="true" focusable="false"` to the SVG. For icon-only links (collapsed state): add `aria-label={item.label}` to the `<Link>` element when collapsed.

CRITICAL

WAI-02

Sidebar Toggle Button Has No Accessible Name (SC 4.1.2)

WCAG 4.1.2 Name, Role, Value — Level A

`engagement-sidebar.tsx` L145-163

The sidebar collapse/expand button uses `title` attribute only. The `title` attribute is not reliably announced by screen readers (especially on mobile AT and VoiceOver) and does not satisfy SC 4.1.2. The button also lacks `aria-expanded` to communicate its current state.

REMEDIATION

Replace `title` with `aria-label`. Add `aria-expanded={!isCollapsed}` and `aria-controls="engagement-nav"`. Add a matching `id="engagement-nav"` to the `<nav>` element.

CRITICAL

WAI-03

Help Modal Fails Multiple WCAG Criteria (SC 4.1.2, 2.1.1, 1.3.1)

WCAG 4.1.2 · 2.1.1 · 1.3.1 — Level A

`sp-help-modal.tsx` L19-242

The SP Help Modal is implemented as a plain `<div>` with no dialog semantics. Six separate failures:

- ① No `role="dialog"` — screen readers don't know it's a dialog.
- ② No `aria-modal="true"` — AT can navigate behind the backdrop.
- ③ No `aria-labelledby` pointing to the `<h2>`.
- ④ Focus is not trapped inside the modal.
- ⑤ Focus is not restored to the trigger on close.
- ⑥ Escape key does not close the modal.

REMEDIATION

Replace with native `<dialog>` element (provides built-in Escape key, focus scoping, and `aria-modal`) or use `@radix-ui/react-dialog` which handles all six issues correctly with minimal API surface.

CRITICAL

WAI-04

Findings InstanceRow Buttons Missing aria-expanded (SC 4.1.2)

WCAG 4.1.2 Name, Role, Value — Level A

findings-client.tsx L83-102

The `InstanceRow` expand/collapse button renders no `aria-expanded` attribute. The expand state is conveyed only by SVG rotation (a visual-only transform). Screen readers cannot determine whether the panel is expanded or collapsed.

REMEDIATION

Add `aria-expanded={open}` and `aria-controls={`finding-detail-${finding.id}`}` to the button. Add `id={`finding-detail-${finding.id}`}` to the expanded panel element.

CRITICAL

WAI-05

Group Header Buttons Missing aria-controls (SC 4.1.2)

WCAG 4.1.2 Name, Role, Value — Level A

findings-client.tsx L428-434

The group header button correctly has `aria-expanded={isExpanded}`, but lacks `aria-controls`. The association between button and controlled panel is positional only — screen reader users cannot programmatically navigate to the expanded content.

REMEDIATION

Add `id` to the expanded content `<div>` (e.g., `id={`group-panel-${groupKey.replace(/:/g, '-')}`}`) and add `aria-controls` to the button referencing that ID.

WAVE 2 — HIGH (LEVEL AA FAILURES)

Required for WCAG AA conformance claim

ID	Sev	Finding	SC	File
WAI-06	High	<code><p className="label-caps"></code> used as section headings — no semantic structure	1.3.1 — A	page.tsx, deliverables/page.tsx, all label-caps instances
WAI-07	High	Risk matrix table missing <code><caption></code> , <code>scope="col"</code> , <code>scope="row"</code> on headers	1.3.1 — A	findings-client.tsx L293-333

ID	Sev	Finding	SC	File
WAI-08	High	Severity filter buttons convey active state via colour only — no aria-pressed	1.4.1 — A	findings-client.tsx L342–368
WAI-09	High	text-navy-400 on white $\approx$ 3.2:1 contrast ratio — fails AA 4.5:1 requirement	1.4.3 — AA	globals.css · all components
WAI-10	High	No global focus-visible styles — keyboard navigation invisible throughout app	2.4.7 — AA	globals.css · btn-teal · sidebar links
WAI-11	High	Discovery progress bar is two empty divs — no role="progressbar" or aria-valuenow	1.1.1 — A	connections-panel.tsx L479–484
WAI-12	High	<details>/<summary> with list-none removes native disclosure marker — AT compatibility risk	2.1.1 — A	connections-panel.tsx L491–525
WAI-13	High	Proportional severity bar conveys information through colour only — no aria-label	1.4.1 — A	findings-client.tsx L273–282
WAI-16	Medium	No skip-to-main-content link — keyboard users must tab through entire header	2.4.1 — A	app/(dashboard)/layout.tsx
WAI-17	Medium	<aside> and <nav> lack aria-label — undistinguishable landmark regions	1.3.6	engagement-sidebar.tsx
WAI-18	Medium	Status badge has no role — dynamic updates not announced to screen readers	4.1.3	status-badge.tsx
WAI-19	Medium	Loading spinner SVGs not hidden from AT — no sr-only live region for "Loading" state	1.3.1 — A	submit-button.tsx · connections-panel.tsx
WAI-14	Medium	External links (target="_blank") missing " (opens in new tab)" accessible text	3.2.5 advisory	sp-help-modal.tsx · findings-client.tsx
WAI-15	Medium	Language of parts not set for technical English code strings (relevant when JA ships)	3.1.2 — AA	sp-help-modal.tsx

ID	Sev	Finding	SC	File
WAI-20	Medium	autocomplete attributes missing on credential and engagement form inputs	1.3.5 — AA	cloud-credentials form · new engagement form
WAI-21	Medium	Select elements use focus:ring-1 (1px) — fails WCAG 2.4.11 minimum focus area	2.4.7 — AA	findings-client.tsx L373–393
WAI-23	Low	Phase stepper steps missing aria-label and aria-current="step"	1.3.1 — A	engagements/[id]/page.tsx L82–128
WAI-22	Low	lang="en" correctly set — future JA locale will require lang="ja" on page/section	3.1.1 — A	layout.tsx (future)



W3C HTML5 & CSS Standards Findings

12
findings

HIGH

W3C-01

Raw `<img>` Elements in Header — Missing width/height, Causing CLS

W3C HTML5 · Core Web Vitals (CLS)

`app/(dashboard)/layout.tsx` L24-33

Two raw `<img>` elements (light/dark CBTS logos) are used instead of Next.js `<Image>`. They lack `width` and `height` attributes, causing Cumulative Layout Shift during page load. Both elements are always in the DOM (only one visible via CSS), doubling image requests. An `eslint-disable` comment suppresses the Next.js lint warning.

REMEDIATION

Replace both `<img>` tags with Next.js `<Image>` components specifying explicit `width` and `height`, and toggle visibility via CSS. Or use a `<picture>` element with a `(prefers-color-scheme: dark)` media source.

HIGH

W3C-02

All Decorative Inline SVGs Missing `aria-hidden` (Pervasive)

W3C SVG 1.1 Accessibility · WAI-ARIA 1.2

All component files — pervasive

Every inline SVG icon across all components (sidebar, findings, connections, deliverables, layout) is decorative — supplementing adjacent text labels — yet none carry `aria-hidden="true"` `focusable="false"`. Screen readers attempt to parse raw SVG path data (e.g., `"M3 1212-2m0 017-7 7 7..."`) as content.

REMEDIATION

Create a shared `<Icon>` wrapper component that automatically applies `aria-hidden="true"` `focusable="false"`. For truly standalone meaningful icons, add a `<title>` element inside the SVG and `role="img"` on the SVG element.

HIGH

W3C-03

Custom Scrollbar Uses Vendor-Prefix Only — W3C Standard Not Implemented

W3C CSS Scrollbars Level 1

globals.css L206-209

The scrollbar styling uses only `::-webkit-scrollbar` pseudo-elements — a non-standard vendor extension. The W3C standard `scrollbar-color` and `scrollbar-width` properties (supported in Chrome 121+, Firefox, Safari 18.2+) are absent. Firefox users see the default OS scrollbar.

REMEDIATION

Add standard properties to all scrollable elements: `scrollbar-width: thin; scrollbar-color: var(--accent) transparent;` Keep the vendor-prefix version as a progressive enhancement for older browsers.

HIGH

W3C-04

-webkit-font-smoothing: antialiased Disables ClearType on Windows

W3C CSS Fonts Level 4 — Non-standard property

globals.css L84-86

`-webkit-font-smoothing: antialiased` is not a W3C standard and on Windows effectively disables ClearType subpixel rendering, making text appear thinner and lower contrast. This negatively impacts readability for the majority of Windows enterprise users — exactly the target audience for this platform.

REMEDIATION

Remove both vendor-prefixed font smoothing declarations, or scope them to macOS only using a `@media screen and (-webkit-min-device-pixel-ratio: 2)` query. Allow the OS to apply its default rendering.

ID	Sev	Finding	Standard	File
W3C-05	Medium	Missing <code><meta name="color-scheme" content="light dark"></code> — white flash on dark mode, broken form control colours	W3C CSS Color Adjust Level 1	app/layout.tsx
W3C-06	Medium	<code>backdrop-filter</code> used without <code>@supports</code> — no explicit opaque fallback for Firefox	W3C Filter Effects Module Level 2	globals.css L109

ID	Sev	Finding	Standard	File
W3C-07	Medium	<summary> list-none removes disclosure marker — Firefox+NVDA compatibility risk	W3C HTML5 <details> semantics	connections-panel.tsx L492
W3C-08	Medium	CSS custom property --bar-pct cast as React.CSSProperties — bypasses TypeScript type safety	W3C CSS Custom Properties / TS	engagements/[id]/page.tsx L194
W3C-09	Medium	rel="noreferrer" without "noopener" — incomplete in older browsers and enterprise WebViews	W3C HTML5 rel attribute	deliverables/page.tsx L183
W3C-10	Medium	Per-deliverable delete <form> elements have no aria-label — identical forms indistinguishable by AT	W3C HTML5 / WAI-ARIA	deliverables/page.tsx L196–208
W3C-11	Low	@theme is a Tailwind CSS v4 proprietary at-rule — not W3C CSS; documents build-tool lock-in	W3C CSS Custom Properties	globals.css L7–36
W3C-12	Low	Dual logo pattern (light/dark) doubles image requests; duplicate alt="CBTS" may confuse AT	W3C HTML5 · CSS media queries	app/(dashboard)/layout.tsx L24–33



Complete Findings Summary Matrix

47
total

ID	Standard	Severity	Title	Wave	Status
OWA-01	OWASP A05	Critical	unsafe-inline script CSP in production	1	Open
OWA-07	OWASP A10	Critical	customerLogoUrl unvalidated — SSRF risk	1	Open
WAI-01	WCAG 1.1.1A	Critical	Navigation SVGs have no accessible name	1	Open
WAI-02	WCAG 4.1.2A	Critical	Sidebar toggle button missing aria-label/aria-expanded	1	Open
WAI-03	WCAG 4.1.2A	Critical	Help modal missing role, focus trap, Escape key	1	Open
WAI-04	WCAG 4.1.2A	Critical	InstanceRow buttons missing aria-expanded	1	Open
WAI-05	WCAG 4.1.2A	Critical	Group header buttons missing aria-controls	1	Open
OWA-02	OWASP A07	High	No rate limiting on Server Actions	2	Open
OWA-03	OWASP A01	High	CSRF bypass on delete engagement action	2	Open
OWA-04	OWASP A07	High	Non-Secure cookie accepted in all environments	2	Open
OWA-05	OWASP A01	High	Job ID enumeration via timing side channel	2	Open
OWA-06	OWASP A04	High	No MIME/magic-byte validation on uploads	2	Open

ID	Standard	Severity	Title	Wave	Status
WAI-06	WCAG 1.3.1A	High	<p> used as section headings throughout	2	Open
WAI-07	WCAG 1.3.1A	High	Risk matrix table missing caption and scope attributes	2	Open
WAI-08	WCAG 1.4.1A	High	Filter buttons convey active state via colour only	2	Open
WAI-09	WCAG 1.4.3AA	High	text-navy-400 fails 4.5:1 contrast ratio	2	Open
WAI-10	WCAG 2.4.7AA	High	No global focus-visible styles	2	Open
WAI-11	WCAG 1.1.1A	High	Progress bar missing role="progressbar"	2	Open
WAI-12	WCAG 2.1.1A	High	<details>/<summary> AT compatibility issue	2	Open
WAI-13	WCAG 1.4.1A	High	Severity bar uses colour only	2	Open
W3C-01	W3C HTML5	High	 without width/height causing CLS	2	Open
W3C-02	W3C SVG	High	All decorative SVGs missing aria-hidden	2	Open
W3C-03	W3C CSS	High	Scrollbar vendor-prefix only — no W3C standard	2	Open
W3C-04	W3C CSS	High	-webkit-font-smoothing disables ClearType on Windows	2	Open
OWA-08	OWASP A02	Medium	useSecureCookies enforcement not verified	3	Open
OWA-09	OWASP A04	Medium	window.confirm() for destructive confirmation	3	Open
OWA-10	OWASP A08	Medium	progressLog parsed without schema validation	3	Open
OWA-11	OWASP A05	Medium	X-Frame-Options SAMEORIGIN on presentation routes	3	Open
OWA-12	OWASP A05	Medium	Raw Azure SDK errors returned to browser	3	Open

ID	Standard	Severity	Title	Wave	Status
OWA-13	OWASP A05	Medium	Permissions-Policy header incomplete	3	Open
OWA-14	OWASP A05	Medium	HSTS missing preload directive	3	Open
OWA-15	OWASP A05	Medium	img-src data: broader than necessary	3	Open
WAI-14	WCAG 3.2.5	Medium	External links missing "(opens in new tab)" text	3	Open
WAI-15	WCAG 3.1.2AA	Medium	Language of parts not set for technical code strings	3	Open
WAI-16	WCAG 2.4.1A	Medium	No skip-to-main-content link	3	Open
WAI-17	WCAG 1.3.6	Medium	<aside>/<nav> missing aria-label	3	Open
WAI-18	WCAG 4.1.3	Medium	Status badge missing role for live updates	3	Open
WAI-19	WCAG 1.3.1A	Medium	Spinner SVGs not hidden from AT	3	Open
WAI-20	WCAG 1.3.5AA	Medium	autocomplete attributes missing on form inputs	3	Open
WAI-21	WCAG 2.4.7AA	Medium	Select focus ring is 1px — fails WCAG 2.4.11	3	Open
W3C-05	W3C CSS	Medium	Missing color-scheme meta tag	3	Open
W3C-06	W3C CSS	Medium	backdrop-filter without @supports fallback	3	Open
W3C-07	W3C HTML5	Medium	<summary> list-none — Firefox+NVDA risk	3	Open
W3C-08	W3C CSS/TS	Medium	--bar-pct cast bypasses TypeScript types	3	Open
W3C-09	W3C HTML5	Medium	rel="noreferrer" missing "noopener"	3	Open
W3C-10	W3C HTML5	Medium	Delete forms missing aria-label	3	Open

ID	Standard	Severity	Title	Wave	Status
OWA- 16	OWASP A05	Low	font-src 'self' — build-time font download fragile	3	Open
OWA- 17	OWASP A05	Low	No Expect-CT header	3	Open
WAI- 22	WCAG 3.1.1A	Low	lang="en" set correctly — future JA locale action needed	3	Open
WAI- 23	WCAG 1.3.1A	Low	Phase stepper steps missing aria-current	3	Open
W3C- 11	W3C CSS	Low	@theme is Tailwind v4 proprietary — not W3C	3	Open
W3C- 12	W3C HTML5	Low	Dual logo doubles requests	3	Open